

Hacking, Phishing and Spoofing — Detailed Lecture Notes

JKSSB Computer Awareness

October 8, 2026

43.1 Why attacks succeed

Most attacks on ordinary computer users do not defeat the machine by force. They persuade the person in front of the screen to hand over the key: a password, a One-Time Password, a click, or a file download. The attacker needs a weakness to use and a moment in which the victim acts without verifying. The weakness may be technical, such as a short reused password or outdated software, or human, such as trust in an authoritative-sounding caller, hurry, or fear of an account being blocked. This lesson stays at a safe awareness level: it names each attack, shows how to recognise it, and teaches the correct defensive response. It does not teach how to carry out any attack.

Definition (Attack chain). A *vulnerability* is a weakness in software, settings, or human habit that can be misused. An *exploit* is a method that takes advantage of such a weakness. An *attack* is the complete harmful act against a person or system. The *payload* is the harmful element the attack delivers, such as stolen credentials, stolen money, or a malicious file.

Term	Meaning in this lesson
Hacking	Gaining unauthorised access to a computer, account, or network.
Phishing	A fake message, mail, or call imitating a trusted sender to steal credentials or money.
Spoofing	Faking an identity, such as a sender address, caller number, or website address.
Social engineering	Tricking a person, rather than breaking software, into giving access.
Password attack	An attempt to discover a password by guessing, a word list, exhaustive trial, or observation.
Malicious link	A web address that leads to a fake page or an unwanted download.
Malicious attachment	A file that harms the computer or steals data when opened.
OTP	One-Time Password: a single-use code; never shared with anyone.

The rest of this lesson uses these terms in one consistent sense. **Hacking** is the broad act of unauthorised access. **Phishing** is fraud by imitation that asks the victim to act. **Spoofing** is the forged identity that makes the fraud look genuine. **Social engineering** is the human manipulation behind both. A **vulnerability** is the weakness, the **exploit** is the method, and the **payload** is the harm delivered.

43.2 Hacking

Hacking means gaining **unauthorised access** to a computer system, an online account, or a network. A **hacker** is the person who performs this act. Access without permission is unlawful even when nothing is copied or damaged; the absence of permission is what defines the act, not the amount of harm that follows.

An **ethical hacker** is a security tester who probes systems **with written permission** from the owner in order to find and fix weaknesses before criminals exploit them. The permission is the entire difference: the same technical step performed with written authorisation is a security test, and performed without it is an attack.

Definition (Hacking). *Gaining access to a computer, account, or network without the owner's permission.*

Example 43.2.1. *A student opens a colleague's mailbox by guessing the password and reads the mail. Even though nothing is deleted, this is hacking, because the access was unauthorised. A bank that hires a tester to try its login page, with a signed agreement, is instead conducting an ethical security test.*

43.3 Password attacks

Passwords remain the most common lock on an account, so attackers try to discover them first. Four methods appear repeatedly in examinations.

Guessing tries obvious choices: the user's name, birth year, phone number, or common strings such as **password123**. **Dictionary attack** tries every entry in a list of common passwords automatically, which succeeds quickly against short familiar words. **Brute-force attack** tries every possible combination of characters until one works; it always succeeds eventually, but a longer password makes the search impractically slow. **Shoulder surfing** is direct observation: watching the keyboard or screen while the victim types a password or PIN.

The defence follows from the methods. Use a **long** password that mixes letters, digits, and symbols, and never reuse one password across accounts. Never disclose a password or an **OTP (One-Time Password)** to anyone, including a caller who claims to represent the bank or the office. Lock the screen when leaving the desk, shield the keypad while typing, and switch on **two-step verification** (also called two-factor authentication) wherever it is offered, so that the password alone is not enough to enter the account.

Definition (Brute-force vs dictionary attack). *A **dictionary attack** tries each word in a ready list of common passwords. A **brute-force attack** tries every possible character combination in turn.*

43.4 Social engineering

Social engineering is the practice of tricking a person into granting access, instead of breaking the software technically. Two named forms recur. **Pretexting** invents a false identity and story — a bank officer verifying records, an IT support engineer fixing the account — to extract a password, OTP, or remote-access permission. **Baiting** offers a lure — a prize, a free recharge, free software — that triggers the victim to click a link or download a file.

The standard signal is manufactured urgency: words such as **urgent**, **blocked**, **suspended**, and **verify now**, combined with a demand to act immediately without checking. The safe response

is fixed: slow down, verify the claim through an independently known channel (the published helpline or the real website), and never disclose a password or OTP under pressure.

Definition (Social engineering). *Manipulating a person, rather than a machine, into revealing credentials or granting access.*

43.5 Phishing

Phishing is a fake message, email, text, or call that **imitates a trusted sender** — a bank, an office, a delivery service — in order to steal passwords, OTPs, card details, or money. The message always contains a call to action: click the enclosed link, open the attached file, or call back the given number. The link leads to a look-alike login page that records whatever is typed; the attachment installs the payload when opened.

Named channels help classification. Fraudulent text messages are called **smishing** (SMS phishing) and fraudulent voice calls are called **vishing** (voice phishing), but both are phishing by the same definition: imitation plus a request for action. The recognition signs are stable: an urgent or threatening tone, spelling and grammar errors, a sender address that does not match the claimed organisation, and a link whose real address differs from the genuine website.

Definition (Phishing). *A fraudulent message that imitates a trusted sender and asks the victim to click, open, reply, or pay, in order to steal credentials or money.*

Example 43.5.1. *A clerk receives a mail headed “Salary slip ready — download within 24 hours or the account will be blocked.” The sender shows the office name, but the reply address is an unknown mailbox and the enclosed link points to a misspelled portal. The mail is phishing: imitation (the office name), pressure (blocking within 24 hours), and a call to action (the link). The safe response is to ignore the link, open the real portal by typing its known address, and report the message.*

43.6 Spoofing

Spoofing means **faking an identity** so that a message, call, or website appears to come from someone it does not. Three forms cover the examination scope. **Email spoofing** forges the “From” address so the mail displays a trusted name that never sent it. **Caller ID spoofing** forges the number shown on the phone so the call appears to come from a bank or office. **Website (URL) spoofing** registers a look-alike address — for instance `bank-verlfy.com` in place of the genuine `bank-verify.com` — and hosts a fake login page there.

Spoofing is best understood as a disguise rather than a complete fraud. A phishing message very often **uses** spoofing — a forged sender address — to look trustworthy, but spoofing can also appear without any message at all, as in a forged website waiting for visitors. The check is the same in every case: confirm the identity through a known channel instead of trusting what is displayed.

Definition (Spoofing). *Presenting a forged sender address, caller number, or website address as though it were genuine.*

43.7 Phishing vs spoofing vs hacking

These three terms form the mandatory near-neighbour set of the lesson, and examination options deliberately mix them. **Hacking** is the broadest: any unauthorised access. **Phishing** is fraud by imitation that asks the victim to act: click, open, reply, or pay. **Spoofing** is the forged identity

itself: the faked address, number, or site. A single incident can contain all three — a forged sender address (spoofing) carries a fake bank mail asking for the OTP (phishing), and the stolen OTP is then used to enter the account (hacking) — but each word answers a different question: was access taken without permission, was a fake message asking for action, or was an identity forged?

43.8 Malicious links and attachments

A **malicious link** is a web address that leads to a fake login page or starts an unwanted download. Before clicking, hover over the link with the mouse to reveal the real address, or long-press it on a phone to preview the destination. Safer still, ignore the link entirely and type the website’s known address by hand. Shortened addresses, misspelled brand names, and extra words inserted into a familiar address, arriving inside an unexpected or urgent message, are warning signs.

A **malicious attachment** is a file that harms the computer or steals data once opened. Never open an unexpected attachment, even when the displayed sender is a known name, because that name may itself be spoofed; confirm with the sender through a separate channel first. Be especially cautious with documents that ask the reader to “enable macros” or “enable content” on opening, since that step is what activates many payloads. In short: the link is the address, the attachment is the file, and both can carry the payload.

43.9 Safe habits and response after targeting

Four habits block the large majority of these attacks. First, verify every urgent request through a **known channel** — the published helpline or the manually typed website — before acting. Second, keep the operating system, browser, and **antivirus** software updated, and scan external drives before opening their files. Third, keep a regular **backup** of important files so that one incident cannot destroy the only copy. Fourth, use the mail client’s **report phishing** option on a suspicious message rather than replying to it or forwarding it to colleagues.

If a suspicious page has already been opened, do not type any password, OTP, or card details into it. Close the page, delete the message, and do not call back any number printed inside it. Change the affected password by visiting the real website directly, inform the bank or office through its published helpline, and preserve a record — a screenshot and the sender’s address — for the complaint. The order is fixed: stop, verify on the real channel, change credentials, report.

43.10 Exam retrieval and common confusions

Six distinctions prevent most errors on this topic.

1. Phishing **imitates** a trusted sender to steal data or money; spoofing **forges** the identity it wears; hacking is the broader **unauthorised access**.
2. OTP stands for **One-Time Password**. No genuine bank, office, or support desk ever asks for it by call or message.
3. A **dictionary** attack tries a ready word list; a **brute-force** attack tries every combination.
4. A **vulnerability** is the weakness, an **exploit** is the method that uses it, and the **payload** is the harm delivered.
5. Ethical hacking requires **written permission**; without it, access is unauthorised.

6. The safe response to any urgent message is fixed: do not click, verify through a known channel, and report.

Example 43.10.1. *An item describes a call in which the displayed number matches the bank's helpline and the caller demands the OTP to "unblock" the account. Trace the definitions: the displayed number is forged (spoofing), the call imitates the bank and demands the OTP (phishing by vishing, using social engineering), and any resulting entry into the account is unauthorised access (hacking). The correct answer names phishing, and the correct action is to refuse, disconnect, and verify through the published helpline.*

Exercises

1. Define hacking, and state what separates an ethical security test from an attack.
2. Distinguish a dictionary attack from a brute-force attack.
3. Define phishing and list four recognition signs of a phishing message.
4. Distinguish phishing from spoofing in one sentence each, and explain how they combine.
5. State the safe response when an unexpected message demands an OTP urgently.

Solutions

1. Hacking is gaining unauthorised access to a computer, account, or network. An ethical security test is performed with the owner's written permission in order to find and fix weaknesses; without that permission the same act is an attack.
2. A dictionary attack tries each entry of a ready list of common passwords; a brute-force attack tries every possible character combination in turn, so longer passwords resist it.
3. Phishing is a fraudulent message imitating a trusted sender in order to steal credentials or money. Signs: urgent or threatening tone, spelling errors, a sender address that does not match the claimed organisation, and a link whose real address differs from the genuine site.
4. Phishing is fraud by imitation that asks the victim to act; spoofing is the forged identity itself. A phishing message often wears a spoofed sender address to look trustworthy.
5. Do not click, reply, or disclose the OTP; verify through an independently known channel (published helpline or manually typed website), change credentials on the real site if exposed, and report the message.